IOT기기에서 MITRE ATT&CK을 활용한 APT 모델 분석 연구

청주대학교 디지털보안학과
김태현

목차

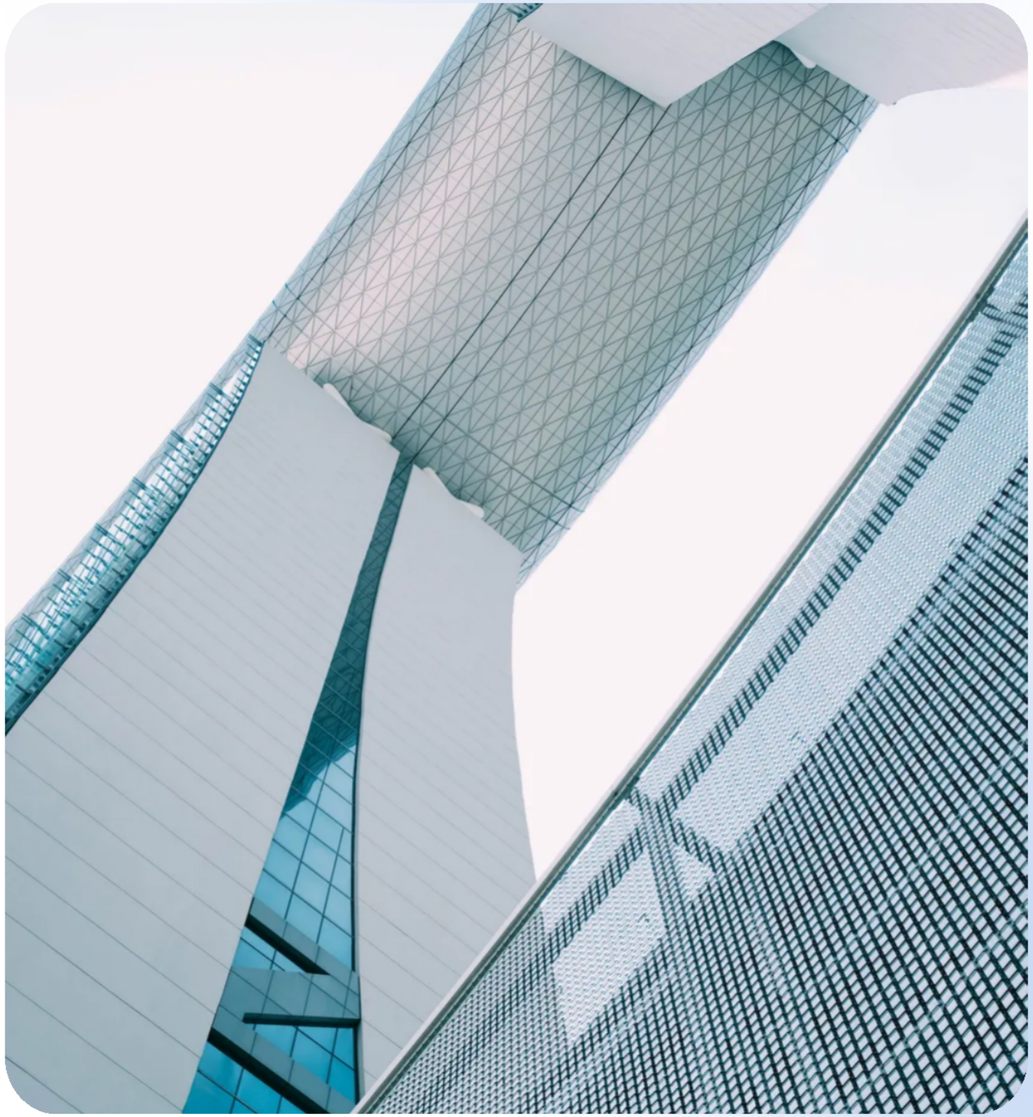
소개 및 배경 01

IoT 취약점 및 위협 모델링 02

제안 APT 공격 시나리오 03

공격 시나리오 비교 분석 04

결론 05



IoT

IoT란?

- 실세계의 장치(Device)가 인터넷에 연결되어 데이터를 수집·전송·처리·제어하는 시스템

IoT 구성 요소

- 센서: 온도·습도·움직임 등 환경 정보 수집
- 엣지 디바이스: Raspberry Pi, MCU 등
- 네트워크: Wi-Fi, Ethernet, 5G
- 애플리케이션: 서비스 제공

그림1. IoT 관련 로고 이미지

IoT

IoT가 취약한 이유

1. 기본 보안 설정이 취약하여 초기 침투 매우 쉽다.

- 기본 계정/약한 비밀번호/패치 부족
- SSH 등 원격 서비스 상시 노출

2. 탐지·모니터링 기능이 부족하여 장기 잠복이 가능하다.

- 이상행위 감지 불가

3. 장치 내부 데이터·권한 보호 미흡하다.

- 센서/설정 데이터 평문 저장
- sudo 등 권한 설정 취약

APT 공격

APT 공격이란?

- 조직적이고 고도화된 공격자가 장기간 은밀하게 특정 목표에 침투하여 정보 수집, 데이터 조작, 파괴 등을 수행하는 표적형 사이버 공격.

APT 공격 과정

초기 침투 → 권한 상승 → 내부 확장 이동 →
정보 수집 → 유출 / 영향(파괴·조작)

Advanced

제로데이 취약점, 맞춤형 악성코드,
정교한 침투기법 사용

Persistent

은밀하게 침투 후 수주~수개월 동안
내부에 머무름

Threat

국가지원 공격 그룹 또는 전문 해킹
조직이 수행

MITRE ATT&CK 프레임워크 개요

MITRE ATT&CK이란?

- 전 세계 공격자가 실제 사용하는 APT 공격 기법(TTP)을 전술(Tactic)–기술(Technique) 구조로 체계화한 프레임워크

- APT 공격은 단계적·조직적·지속적 공격이므로 ATT&CK는 APT의 행동 패턴을 분석·모델링하기 위한 표준 도구

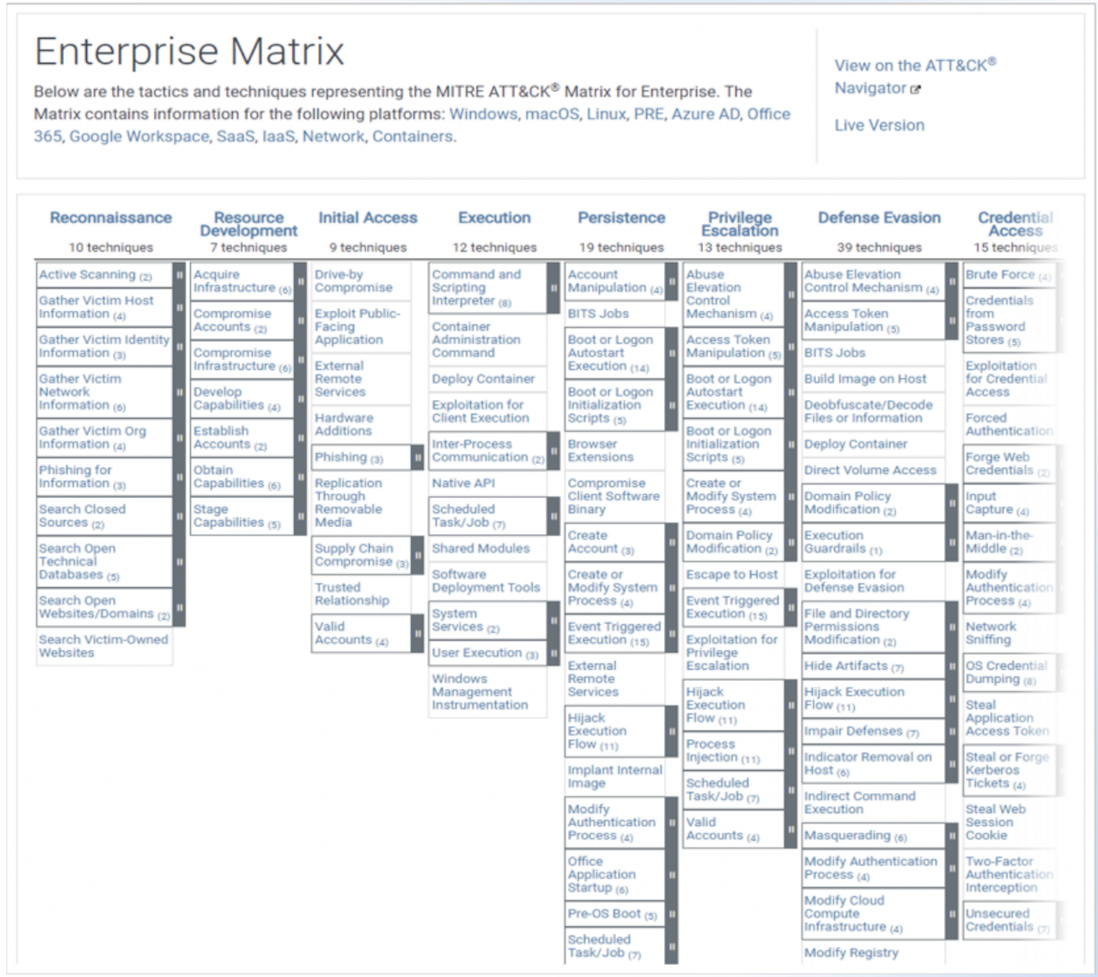


그림2. MITRE ATT&CK Enterprise Matrix

MITRE ATT&CK 프레임워크 개요

MITRE Caldera란?

- ATT&CK 기반으로 만들어진공격 자동화 시뮬레이션 도구
- 공격자 시나리오, 공격 기술을 ATT&CK 기술과 1:1로 매핑하여 실제 APT 공격 흐름을 자동 재현
- IoT·서버 환경에서 Privilege Escalation → Persistence → Collection → Exfiltration 같은 APT의 전체 공격 단계 수행 가능

그림3. MITRE Caldera 로고

문제 가정

MITRE Caldera라는 도구를 활용했을 때 IoT가 APT 공격들에 취약한지 확인할 수 있을까?

IoT가 APT공격을 당했을 때 얼마나 취약할까?

IoT 취약점

01

약한 인증 및 기본 계정

IoT 기기들은 기본 계정이나 약한 비밀번호가 그대로 사용되는 경우가 많아 공격자가 손쉽게 초기 접근 권한을 획득 가능

02

외부에 노출된 원격 관리 서비스

SSH·HTTP 등 원격 관리 인터페이스가 보호 없이 노출되어 있어 공격자는 네트워크를 통해 직접 명령을 실행하거나 시스템 내부로 진입 가능

03

권한 및 파일 시스템 설정 미흡

sudo 설정 오류나 과도한 파일 권한 부여와 같은 관리적 실수로 인해 공격자가 손쉽게 권한을 상승시키고 시스템을 장악 가능

04

지속성 관리 부족

cron, systemd와 같은 자동 실행 메커니즘이 제대로 보호되지 않아 공격자가 악성 스크립트나 백도어를 지속적으로 유지하기 쉽다.

05

민감 데이터 및 로그 보호 미흡

설정 파일, 센서 데이터, 시스템 로그가 평문으로 저장되거나 접근 통제가 부족해 공격자가 데이터를 수집·조작하거나 흔적을 은폐하기 매우 쉽다.

MITRE ATT&CK 기반 위협 모델링

- 약한 인증/기본 계정 → Valid Accounts (T1078)
- 원격 관리 서비스 노출 → Remote Services (T1021)
- 권한 설정 오류·sudo 오남용 → Privilege Escalation (T1068/T1548)
- cron·service 관리 미흡 → Persistence (T1053)
- 데이터/로그 보호 미흡 → Data from Local System (T1005), Stored Data Manipulation (T1565.001), Log Tampering (T1070)

APT 공격 환경

1. Attacker System

- 공격자 역할 수행

2. Caldera Server

- APT 공격 자동화 플랫폼
- Agent에게 공격 명령 전달

3. Raspberry Pi

- IoT 환경의 “게이트웨이/중간 제어 장치” 역할
- IoT 데이터를 보유하거나 제어하는 핵심 노드

4. IoT Devices

- Raspberry Pi를 통해 제어되는 장비
- 센서 데이터 / 설정 정보 등이 공격에 의해 변조 또는 유출됨

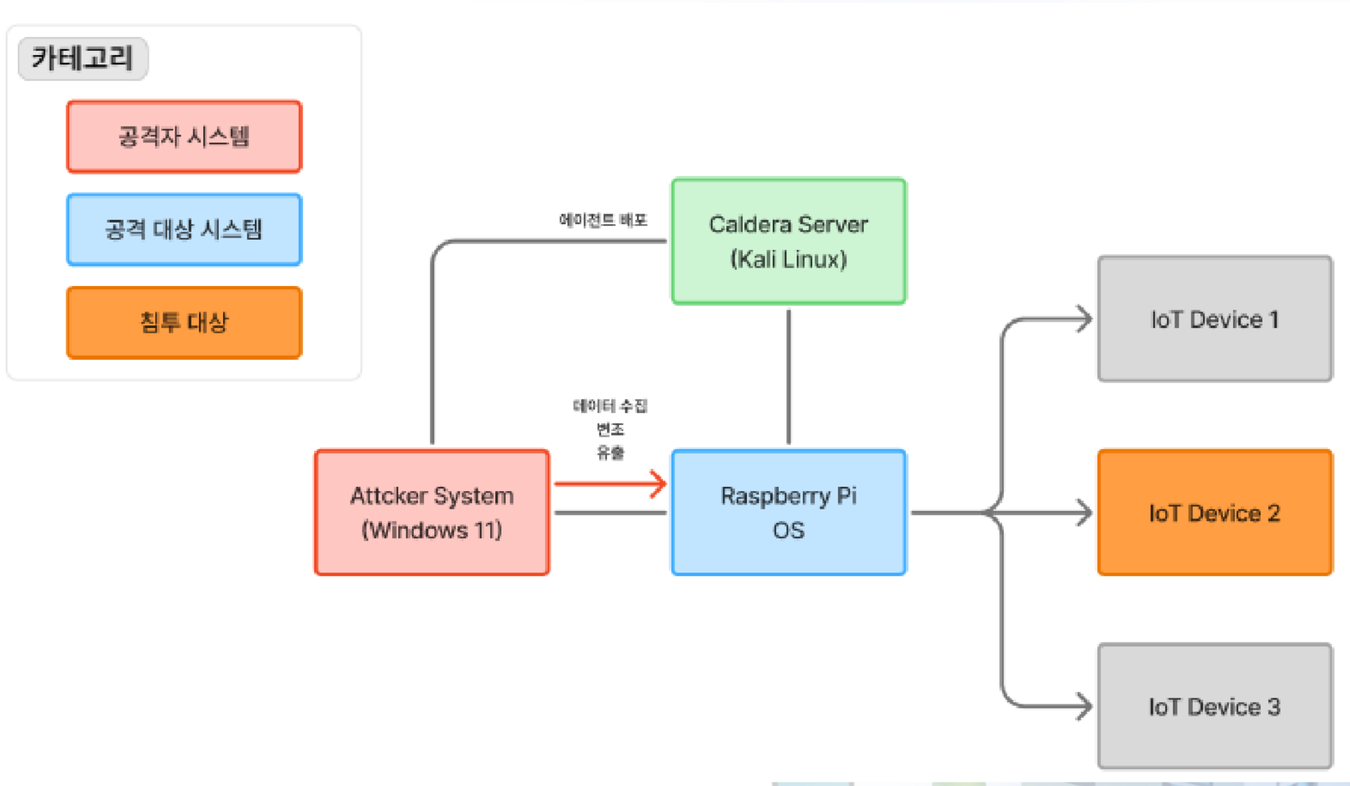


그림5. APT 공격 환경 흐름도

공격 시나리오 설계 배경

앞서 분석한 IoT 취약점과 MITRE ATT&CK 매핑 결과를 기반으로, 실제 APT 공격이 IoT 환경에서 어떤 단계로 전개되는지 검증하기 위해 두 가지 공격 시나리오를 설계

시나리오 설계 목적

시나리오 1 - 정보 수집 기반 데이터 유출 공격

- IoT 기기가 APT 초기 단계(Discovery·Collection·Exfiltration) 에 얼마나 취약한지 확인
- 정보 수집과 유출이 얼마나 쉽게 이루어지는지 실험적 분석

시나리오 2 - 권한 상승·지속성 확보·데이터 변조 공격

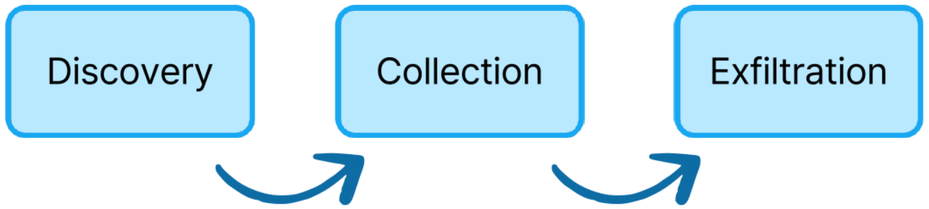
- IoT 장치가 권한 상승·지속성 확보·데이터 변조·은폐 등 APT 중·후반부 공격에 얼마나 취약한지 평가
- 공격자가 장기적으로 장치를 통제할 수 있는지 실증 검증

시나리오 1 - 정보 수집 기반 데이터 유출 공격

공격 목적

- IoT 장비가 갖고 있는 내부 정보(센서 데이터/설정값/로그 등)를 탐지·수집
- 공격자가 수집한 정보를 Base64 기반으로 외부 유출

공격 흐름



Tactic	Sub Technique	설명
Discovery	T10821 System Information Discovery	대상 시스템의 OS, 버전, 네트워크 등 기본 환경 정보를 수집하는 기술
Discovery	T1083 File and Directory Discovery	특정 경로나 파일 구조를 탐색하여 유용한 데이터를 찾아내는 기술
Collection	T1005 Data from Local System	로컬 파일 시스템에서 민감 데이터 또는 분석에 필요한 정보를 직접 가져오는 기술
Exfiltration	T1041 Exfiltration Over Command and Control Channel	수집된 데이터를 C2 채널(예: Caldera)로 전송하여 은밀하게 유출하는 기술

표1. 시나리오 1 MITRE ATT&CK 전술 및 기술 매핑

시나리오 1 - 정보 수집 기반 데이터 유출 공격

Standard Output

```
Linux raspberry 5.10.0-15-amd64 #1 SMP Debian 5.10.120-1 (2022-06-09) x86_64 GNU/Linux
PRETTY_NAME="Debian GNU/Linux 11 (bullseye)"
NAME="Debian GNU/Linux"
VERSION_ID="11"
VERSION="11 (bullseye)"
VERSION_CODENAME=bullseye
ID=debian
HOME_URL="https://www.debian.org/"
SUPPORT_URL="https://www.debian.org/support"
BUG_REPORT_URL="https://bugs.debian.org/"
```

그림6. 공격 대상 시스템의 시스템 정보

Standard Output

```
[COLLECT_IOT_DUMMY_DATA]

===== BEGIN FILE: /home/pi/iot_data/device_info.json =====
{
    "device_id": "RP-FAKE-001",
    "model": "RaspberryPi 4 Model B",
    "location": "Test_Lab_01",
    "firmware_version": "v1.0.3",
    "last_update": "2025-01-01"
}

===== END FILE: /home/pi/iot_data/device_info.json =====


===== BEGIN FILE: /home/pi/iot_data/device_config.ini =====
[network]
device_id = RP-TEST-DEVICE
wifi_ssid = TEST_NETWORK
wifi_password = FAKE_PASSWORD_123

[sensor]
sampling_rate = 10
threshold_temp = 30
```

그림7. 공격 대상 시스템의 IoT 파일 수집 정보

Standard Output

```
W25ldHdvcmtdCmRldmljZV9pZCA9IFJQLVRFU1QtREVWSUNFCndpZmlfc3NpZCA9IFRFU1RfTkVU
VO9SSwp3aWZpX3Bhc3N3b3JkID0gRkFLRV9QQVNTV09SRF8xMjMKCltzZW5zb3JdCnNhbXBsaW5n
X3JhdGUgPSAxMAp0aHJlc2hvbGRfdGVtcCA9IDMwCg==
```

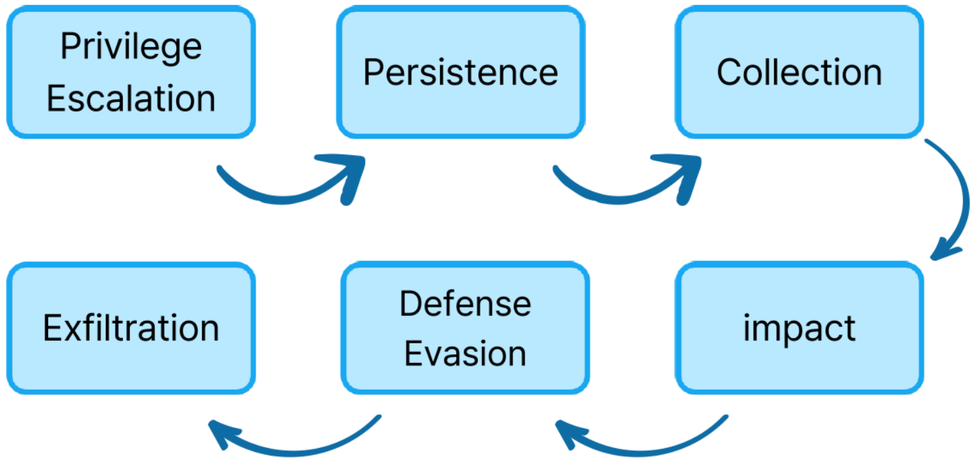
그림8. IoT 데이터를 Base64 인코딩으로 값 유출

시나리오 2 - 권한 상승·지속성 확보·데이터 변조 공격

공격 목적

- IoT 장비가 갖고 있는 내부 정보(센서 데이터/설정값/로그 등)를 탐지·수집
- 공격자가 수집한 정보를 Base64 기반으로 외부 유출

공격 흐름



Tactic	Sub Technique	설명
privilege-escalation	T1069.001 **Permission Groups Discovery: Local Groups**	sudo 권한 확인으로 상승 가능성 탐색
persistence	T1053.003 **Scheduled Task/Job: Cron**	cron 작업 추가로 지속적 실행 환경 확보
collection	T1005 **Data from Local System**	로컬 센서 데이터 파일 읽기
impact	T1565.001 **Data Manipulation: Stored Data Manipulation**	센서 데이터 조작 및 변조
defense-evasion	T1562 **Impair Defenses**	로그 위조로 공격 흔적 은폐
exfiltration	T1041 **Exfiltration Over C2 Channel**	변조 데이터를 C2로 유출

표2. 시나리오 2 MITRE ATT&CK 전술 및 기술 매핑

시나리오 2 - 권한 상승·지속성 확보·데이터 변조 공격

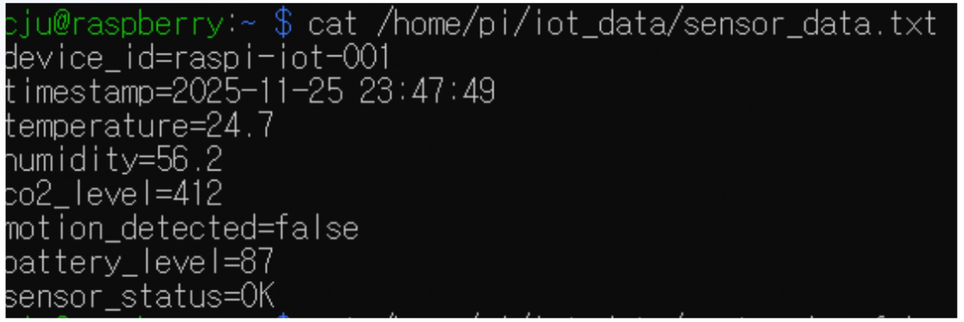


그림9. 정상적인 IoT 센서 정보

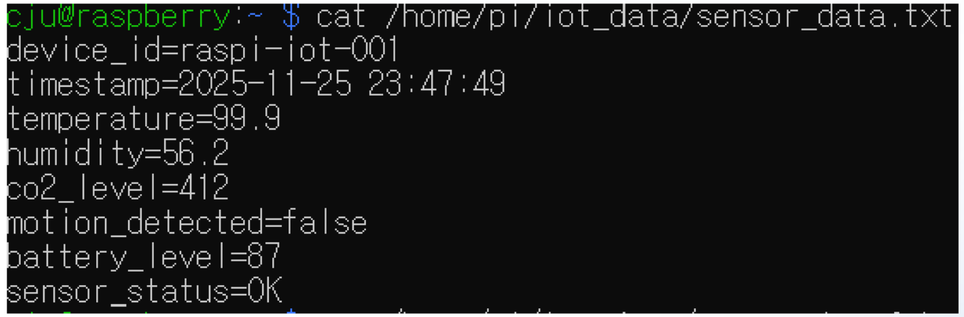


그림10. 변조된 IoT 센서 정보

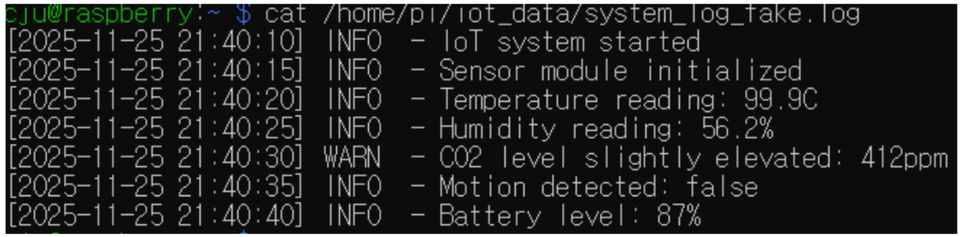


그림11. 정상적인 IoT 로그 정보

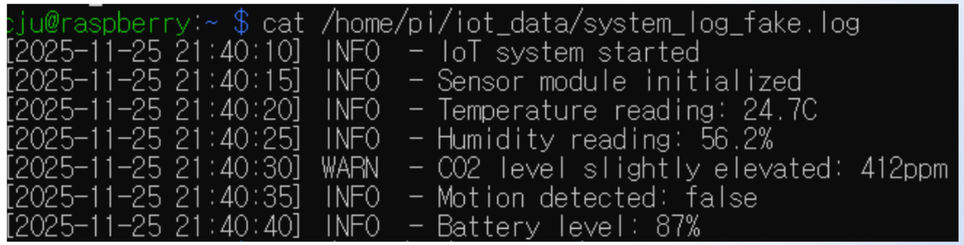


그림11. 변조된 IoT 로그 정보

MITRE ATT&CK 매핑 비교

- 시나리오 1은 Discovery → Collection → Exfiltration 중심의 초기 단계 APT 공격을 재현.
- 시나리오 2는 PrivEsc → Persistence → Impact → Evasion까지 포함한 전체 APT 흐름을 구현.

단계	시나리오 1	시나리오 2
Privilege Escalation	-	T1069.001, T1068
Persistence	-	T1053.003
Discovery	T1082, T1083	부분적 수행
Collection	T1005	T1005
Impact	-	T1565.001
Defense Evasion	-	T1562/T1070
Exfiltration	T1041	T1041

표3. 시나리오 1, 2의 MITRE ATT&CK 전술 및 기술 매핑 비교

MITRE ATT&CK 매핑 비교

시나리오 1 피해 영향

1. 정보 노출 피해

- IoT 기기의 민감 데이터(device_info.json, config.ini) 유출
- 시스템 내부 구조 및 설정 정보가 공격자에게 그대로 전달됨

2. 추가 공격 가능성 증가

- 네트워크 정보, 장비 설정이 노출되어 추가적인 권한 상승 또는 장기 공격 기반 제공

시나리오 2 피해 영향

1. 시스템 장악 및 조작 피해

- cron 지속성 확보로 지속적인 공격자 제어권 유지
- 센서 데이터 변조로 물리적 제어 오작동 가능성 발생 (예: 온도값 임의 조작 → 제어 시스템 오작동)

2. 은폐된 공격으로 탐지 어려움

- 로그 위조로 인해 공격 흔적이 사라져
- 전통적인 모니터링 체계로 탐지가 어려움

5. 결론

연구 요약

- Raspberry Pi를 IoT 게이트웨이로 설정하고, Caldera(C2) 기반으로 **정보수집→권한상승→지속성→데이터 변조→유출**의 공격 단계를 시나리오로 설계·실행
- 이를 통해 IoT 기기의 구조적 취약점(권한 관리, 파일 보호, 지속성, 무결성 등)이 APT 공격 전 단계에서 악용될 수 있음을 실험적으로 검증
- 두 시나리오 비교를 통해 정보 유출형 공격뿐 아니라 장기지속·조작형 공격에도 IoT 환경이 매우 취약함을 밝힘으로써 IoT 보안 대응의 우선순위를 제시

향후 제언

- IoT 기기에 대한 권한관리·로그 무결성·지속성 탐지 기능 강화 필요
- 센서·운영 데이터 변조 대비를 위한 무결성 검증 기술 도입(해시/서명 기반) 필요
- Caldera 기반 실험 환경을 스마트홈·산업 IoT 등 다양한 기기군으로 확장하여 공격 영향 분석 연구 확대

Thank You